

Table of Contents

Estado de revisión: Borrador de traducción asistida por máquina. Requiere revisión humana de terminología, significado, enlaces, formato y vigencia técnica antes de marcarse como edición final.

SERIE DE CIBERSEGURIDAD, PRIVACIDAD Y CUMPLIMIENTO

ISO/IEC 27001:2022 " ISO/IEC 27002:2022

**** ISMS práctico, riesgos, auditorías, controles y herramientas de código abierto****

Un manual de trabajo para administradores, analistas junior, estudiantes, cambiadores de carrera, auditores internos y equipos de seguridad

Alberto (Al) Leiva

Primera edición • Julio 2026

Contenido: Cláusulas 4–10 • los 93 controles del Anexo A • riesgo • Declaración de Aplicabilidad • auditoría • certificación • evidencia • herramientas • laboratorios • preparación profesional |

Aviso de publicación y uso

Autor: Alberto (Al) Leiva

Edición: Primera edición, Julio 2026

Este manual educativo independiente no es una publicación ISO, asesoría legal, decisión de certificación, informe de auditoría o sustituto de las normas ISO/IEC licenciadas. Las publicaciones ISO tienen derechos de autor. Las descripciones de control y cláusulas aquí son resúmenes originales; use las normas oficiales para requisitos y orientación exactos.

ISO desarrolla estándares pero no certifica organizaciones. La certificación es opcional y es realizada por los organismos de certificación. Verifique la acreditación, alcance, ubicación, versión y estado de certificado antes de confiar en una reclamación de certificación.

Uso ético y autorizado

Utilice herramientas técnicas únicamente en sistemas, aplicaciones, redes, cuentas de nube, repositorios y datos que posee o está específicamente autorizado por escrito para evaluar. Use datos sintéticos y sistemas aislados en laboratorios.

Prefacio

Una introducción práctica a la gestión de la seguridad de la información y las garantías basadas en pruebas.

ISO/IEC 27001 es una norma de requisitos para establecer, aplicar, mantener y mejorar continuamente un sistema de gestión de la seguridad de la información. Utiliza la gestión del riesgo para preservar la confidencialidad, la integridad y la disponibilidad de una manera que se ajuste a la organización. ISO/IEC 27002 proporciona orientación de control detallada pero no es en sí mismo un estándar de certificación.

Las ediciones base actuales son ISO/IEC 27001:2022 y ISO/IEC 27002:2022. ISO/IEC 27001:2022 La enmienda 1:2024 añade un examen explícito del cambio climático al contexto organizativo y observa que las partes interesadas pueden tener requisitos relacionados con el clima. La enmienda no significa que cada organización debe crear un programa climático; debe hacer y apoyar una determinación razonada de relevancia dentro del contexto ISMS.

Un ISMS exitoso no es una carpeta de políticas. Es un sistema de gestión funcional: los líderes establecen dirección, los propietarios de riesgos toman decisiones de tratamiento informadas, los equipos operan controles, las pruebas de auditoría interna del sistema, los resultados de los exámenes de gestión y la acción correctiva evita la recurrencia.

Cómo utilizar este manual

Los administradores deben comenzar con los Capítulos 1–5 y 18–23.

Los analistas juniores deben estudiar cláusulas, temas del anexo A, pruebas de evidencia, herramientas, laboratorio y preparación de entrevistas.

Los auditores internos deben centrarse en criterios objetivos, independencia, poblaciones completas, muestreo, conclusiones, medidas correctivas y seguimiento.

Las organizaciones que solicitan la certificación deben confirmar las normas, enmiendas, alcance de certificación y expectativas de acreditación con los profesionales competentes.

Tabla de contenido en Word: Este documento contiene un campo nativo de tabla de contenido y una estructura de capítulos verificada. Después de editarlo, haga clic con el botón derecho en la tabla de contenido, seleccione **Actualizar campo** y luego **Actualizar toda la tabla**. # Tabla de contenidos

[Notificación de publicación y uso \[2\]](#)

[Uso ético y autorizado \[2\]](#)

[Prefacio \[3\]](#)

[Cómo utilizar este manual \[4\]](#)

[Tabla de contenidos \[4\]](#)

1. Fundamentos de ISO/IEC 27001 y 27002 [7]
2. Alcance del SGSI y partes interesadas [8]
3. Evaluación del riesgo y tratamiento del riesgo [9]
4. Declaración de aplicabilidad [10]
5. Documentación y pruebas [11]
6. Cláusula 4 — Contexto de la organización [12]
7. Cláusula 5 — Liderazgo [13]
8. Cláusula 6 — Planificación [14]
9. Cláusula 7 - Apoyo [15]
10. Cláusula 8 — Operación [16]
11. Cláusula 9 — Evaluación del desempeño [17]
12. Cláusula 10 — Mejora [18]
13. Anexo A 5 Controles de organización [19]
14. Anexo A 6 Controles de personas [22]
15. Anexo A 7 Controles físicos [23]
16. Anexo A 8 Controles tecnológicos [24]
17. Implementing Controls with ISO/IEC 27002 [26]
18. Pruebas de medición y control [27]
19. Auditoría interna [28]
20. Revisión por la dirección y acción correctiva [29]
21. Preparación para la certificación [30]
22. Herramientas de código abierto [31]
 - 22.1 Auxiliar de CISO [31]
 - 22.2 Comunidad SimpleRisk [31]
 - 22.3 Wazuh [31]
 - 22.4 osquery [32]
 - 22.5 OpenSCAP [32]
 - 22.6 Greenbone Community Edition [32]

- 22.7 Nmap [32]
- 22.8 Trivy [32]
- 22.9 OWASP ZAP [33]
- 22.10 Keycloak [33]
- 22.11 DefectDojo [33]
- 22.12 AIDE [33]
- 22.13 Lynis [33]
- 22.14 Agente de política abierta [33]
- 23. Manual del SGSI para gerentes [35]
- 24. Guía de la carrera de analista junior [36]
 - 24.1 Trabajo junior típico [36]
 - 24.2 Habilidades que valoran los empleadores [37]
- 25. Laboratorio ficticio y portafolio [38]
- 26. Plan de aprendizaje de 30 días [39]
- 27. Preparación de entrevistas [40]
 - 27.1 ¿Qué es un ISMS? [40]
 - 27.2 ISO 27001 versus 27002? [40]
 - 27.3 ¿Cuál es el SoA? [40]
 - 27.4 ¿Todos los controles del anexo A son obligatorios? [40]
 - 27.5 ¿Cómo se prueba un control? [40]
 - 27.6 ¿Qué es una no conformidad? [40]
 - 27.7 ¿Qué cambió en 2024? [40]
 - 27.8 ¿Qué puede concluir un analista junior con seguridad? [40]
 - 27.9 Preguntas para hacer al empleador [40]
- 28. Plantillas, Glosario, Índice y Referencias [42]
 - 28.1 Registro mínimo de riesgo [42]
 - 28.2 Documentos de prueba de control [42]
 - 28.3 Glosario [42]

28.4 Índice de asunto [43]

28.5 Referencias oficiales [43] # 1. Fundamentos de ISO/IEC 27001 y 27002

Ediciones actuales, propósito, relación y limitaciones importantes.

Gráfico 1 Ciclo de mejora continua de los ISMS

Documento	Función	Certificación
ISO/IEC 27001:2022	Requisitos normativos del SGSI, incluidos los controles de referencia del Anexo A	Las organizaciones pueden certificarse conforme a esta norma
ISO/IEC 27001:2022/Amd 1:2024	Cambios relacionados con la acción climática que afectan al contexto y a la consideración de las partes interesadas	Se aplica junto con la norma base
ISO/IEC 27002:2022	Orientación para implementar controles de seguridad de la información	No es una norma de certificación
ISO/IEC 27005:2022	Orientación para la gestión del riesgo de seguridad de la información	Orientación de apoyo; no es la norma de certificación ISO/IEC 27001
- Las cláusulas 4-10 contienen requisitos que una organización debe abordar para su conformidad. - En el Anexo A se enumeran 93 controles de referencia en cuatro temas: 37 organizativos, 8 relacionados con personas, 14 físicos y 34 tecnológicos. - La selección de control sigue el tratamiento de riesgos y las obligaciones aplicables; el anexo A no es una lista de verificación universal en la que siempre debe aplicarse cada control. - La Declaración de aplicabilidad registra los controles necesarios, la justificación, el estado de aplicación y las exclusiones justificadas del anexo A.		

2. Alcance del SGSI y partes interesadas

Cómo definir un límite defensible para el sistema de gestión.

- Identificar objetivos comerciales, productos, servicios, procesos, información, entidades jurídicas, lugares, personas, proveedores, tecnologías y dependencias.
- Comprender las cuestiones internas pertinentes, como la estrategia, la cultura, las aptitudes, la arquitectura, la gobernanza y los recursos.

- Comprender cuestiones externas relevantes como amenazas, leyes, contratos, mercados, proveedores, condiciones físicas y cambio tecnológico.
- Determinar las partes interesadas y los requisitos pertinentes, incluidos los clientes, reguladores, trabajadores, propietarios, proveedores, comunidades y partes interesadas en la certificación.
- Considerar si el cambio climático es relevante para la eficacia del SGSI y si las partes interesadas tienen requisitos relacionados con el clima; documentar el razonamiento.
- Definir límites de alcance, interfaces, exclusiones, dependencias y justificación en lenguaje que pueda ser auditado.
- Mantenga el alcance alineado con los inventarios de activos, procesos, red, nube, proveedor y flujo de datos.

**** Prueba de la encuesta**** ¿Qué entidades jurídicas, sitios, servicios, procesos y tecnología están incluidas? | Declaración y mapas aprobados del alcance | INTERCAMBIO | ¿Qué conecta el alcance con otros equipos, sistemas, proveedores y ubicaciones? flujos de datos, arquitectura, contratos, matriz de responsabilidad ¿Podría ocultarse información importante o riesgo fuera del límite establecido? | Reconocimiento de inventarios y descubrimientos | ¿Qué desencadena una revisión de alcance? | Cambio de registros, adquisiciones y puertas de producto | ¿Podrían los efectos climáticos o las expectativas de los interesados afectar a la disponibilidad, proveedores, instalaciones, personas o obligaciones? | Análisis de contexto, decisión, acciones cuando sea relevante

3. Evaluación de riesgos y tratamiento de riesgos

Un método repetible que conecta el riesgo empresarial para controlar las decisiones.

Gráfico 2 Corriente de trabajo sobre el riesgo de seguridad de la información

Definir los criterios de riesgo antes de anotar: método de identificación de riesgos, escalas de probabilidad y consecuencias, reglas de cálculo, umbrales de aceptación, tratamiento requerido, escalada, frecuencia de revisión y autoridad propietaria de riesgos. Aplicar el método lo suficientemente consistente para producir resultados válidos y comparables.

Campo	Contenido de ejemplo
Activo u objetivo	Portal del cliente y disponibilidad exigida contractualmente
Evento de amenaza	Robo de credenciales seguido de acceso administrativo no autorizado
Vulnerabilidad o condición	Inscripción débil y ausencia de MFA resistente al phishing
Consecuencias	Divulgación de datos, interrupción, incumplimiento contractual y costo de respuesta

Campo	Contenido de ejemplo
Controles existentes	MFA, acceso condicional, registro y verificación de soporte
Riesgo inherente o actual	Puntuación conforme a criterios aprobados de probabilidad y consecuencia
Tratamiento	Modificar el riesgo mediante una autenticación más sólida y una recuperación monitoreada
Propietario y fecha	Propietario responsable del riesgo y fecha objetivo designados
Riesgo residual	Reevaluar después del tratamiento y obtener la aprobación explícita del propietario

4. Declaración de aplicabilidad

El puente entre el tratamiento del riesgo, el anexo A, otros controles y pruebas de auditoría.

Figura 3. Flujo de trabajo de la Declaración de Aplicabilidad

- Enumerar los controles necesarios para tratar los riesgos identificados de seguridad de la información y cumplir los requisitos legales, regulatorios, contractuales y empresariales.
- Comparar los controles seleccionados con el Anexo A para comprobar que no se hayan omitido controles de referencia necesarios.
- Registrar si cada control del Anexo A es aplicable y justificar su inclusión o exclusión.
- Registrar claramente el estado de implementación y mantenerlo alineado con el plan de tratamiento de riesgos y la evidencia operativa.
- Incluir controles específicos de la organización cuando el anexo A no se ocupa plenamente de un riesgo.
- Controlar la Declaración de Aplicabilidad como información documentada y actualizarla después de cambios materiales en el riesgo, el alcance, los requisitos legales, los proveedores, la tecnología o los controles.

Control	¿Aplicable?	Justificación	Estado	Responsable / evidencia
Ejemplo 8.15: registro de eventos	Sí	Necesario para la detección, la investigación y el cumplimiento de obligaciones	Implementado con acciones abiertas	Operaciones de Seguridad / inventario de fuentes y registros de revisión

Control	¿Aplicable?	Justificación	Estado	Responsable / evidencia
Ejemplo 7.9: activos fuera de las instalaciones	Sí	El personal remoto y en viaje utiliza dispositivos de la organización	Implementado	Operaciones de TI / inventario y evidencia de cifrado
Ejemplo de control específico de la organización	Sí	Un riesgo específico de seguridad del producto exige versiones firmadas	Parcialmente implementado	Ingeniería / registros de la canalización
Ejemplo de exclusión	No	La tecnología o el escenario descritos no existen dentro del alcance controlado	No aplicable	Evidencia del alcance y de la arquitectura

5. Documentación y evidencia

Cómo mantener información documentada útil sin crear burocracia.

Figura 4. Cadena de requisitos a evidencia

Documento o registro	Propósito	Comprobaciones de control
Alcance del SGSI	Define los límites y las interfaces	Aprobado, vigente y coherente con la realidad
Política	Establece la dirección y los compromisos	Aprobada, comunicada y revisada
Método y registro de riesgos	Demuestra una evaluación y unas decisiones repetibles	Criterios aplicados de forma coherente; los propietarios aprueban el riesgo residual
Plan de tratamiento de riesgos	Registra acciones, responsables, recursos y fechas	Alineado con los riesgos y la Declaración de Aplicabilidad
Declaración de Aplicabilidad	Explica la selección y el estado de los controles	Todos los controles del Anexo A están abordados y las justificaciones están sustentadas
Objetivos y métricas	Muestra los resultados previstos y su evaluación	Medibles, con responsables, analizados y sujetos a

Documento o registro	Propósito	Comprobaciones de control
Registros de competencia y concientización	Sustentan la capacidad y la comprensión	acciones Basados en funciones, evaluados y vigentes
Evidencia operativa	Demuestra que los controles funcionaron realmente	Completa, auténtica, protegida y conservada
Registros de auditoría y revisión	Sustentan la supervisión y las decisiones	Objetivos, completos y con seguimiento
Registros de acciones correctivas	Demuestran la causa raíz y una corrección eficaz	Causa abordada, recurrencia considerada y eficacia verificada

6. Cláusula 4 - Contexto de la organización

Requisitos de idiomas, enfoque de verificación y pruebas de ejemplo.

Propósito de la cláusula: Contexto de la organización

Cláusula	Significado claro	Enfoque de verificación	Evidencia de ejemplo
4.1	Comprender las cuestiones internas y externas que pueden afectar al SGSI; considerar explícitamente si el cambio climático es pertinente.	Confirmar la propiedad, el alcance, el método, la aprobación, la evidencia operativa, las excepciones, la corrección y los registros conservados.	Políticas, registros, planes, actas, resultados, aprobaciones y evidencia de seguimiento
4.2	Identificar las partes interesadas pertinentes, sus requisitos y si incluyen expectativas relacionadas con el clima.	Confirmar la propiedad, el alcance, el método, la aprobación, la evidencia operativa, las excepciones, la corrección y los registros conservados.	Políticas, registros, planes, actas, resultados, aprobaciones y evidencia de seguimiento
4.3	Definir y mantener el alcance del SGSI, incluidos límites,	Confirmar la propiedad, el alcance, el método, la	Políticas, registros, planes, actas, resultados,

Cláusula	Significado claro	Enfoque de verificación	Evidencia de ejemplo
	interfaces, dependencias, ubicaciones, tecnología y exclusiones.	aprobación, la evidencia operativa, las excepciones, la corrección y los registros conservados.	aprobaciones y evidencia de seguimiento
4.4	Establecer, operar, mantener y mejorar continuamente el SGSI y sus procesos requeridos.	Confirmar la propiedad, el alcance, el método, la aprobación, la evidencia operativa, las excepciones, la corrección y los registros conservados.	Políticas, registros, planes, actas, resultados, aprobaciones y evidencia de seguimiento

Utilice el texto oficial licenciado ISO/IEC 27001 para requisitos normativos exactos. Este manual parafrasea conceptos para la educación y no reemplaza el estándar.

Enmienda de 2024: Determinar explícitamente si el cambio climático es pertinente para el contexto del SGSI y reconocer que las partes interesadas pertinentes pueden tener requisitos relacionados con el clima. Conservar evidencia del razonamiento y de cualquier acción resultante.

7. Cláusula 5 - Liderazgo

Requisitos de idiomas, enfoque de verificación y pruebas de ejemplo.

Propósito de la cláusula: Liderazgo

Cláusula	Significado claro	Enfoque de verificación	Evidencia de ejemplo
5.1	La alta dirección demuestra compromiso, integra el SGSI en los procesos empresariales, proporciona recursos y apoya la mejora.	Confirmar la propiedad, el alcance, el método, la aprobación, la evidencia operativa, las excepciones, la corrección y los registros conservados.	Políticas, registros, planes, actas, resultados, aprobaciones y evidencia de seguimiento
5.2	Establecer,	Confirmar la	Políticas, registros,

Cláusula	Significado claro	Enfoque de verificación	Evidencia de ejemplo
	comunicar y mantener una política de seguridad de la información adecuada para la organización.	propiedad, el alcance, el método, la aprobación, la evidencia operativa, las excepciones, la corrección y los registros conservados.	planes, actas, resultados, aprobaciones y evidencia de seguimiento
5.3	Asignar y comunicar las responsabilidades de seguridad de la información y la autoridad para informar.	Confirmar la propiedad, el alcance, el método, la aprobación, la evidencia operativa, las excepciones, la corrección y los registros conservados.	Políticas, registros, planes, actas, resultados, aprobaciones y evidencia de seguimiento

Utilice el texto oficial licenciado ISO/IEC 27001 para requisitos normativos exactos. Este manual parafrasea conceptos para la educación y no reemplaza el estándar.

8. Cláusula 6 - Planificación

Requisitos de idiomas, enfoque de verificación y pruebas de ejemplo.

Propósito de la cláusula: Planificación

Cláusula	Significado claro	Enfoque de verificación	Evidencia de ejemplo
6.1.1	Determinar los riesgos y las oportunidades a nivel del SGSI, planificar acciones, integrarlas en los procesos del SGSI y evaluar su eficacia.	Confirmar la propiedad, el alcance, el método, la aprobación, la evidencia operativa, las excepciones, la corrección y los registros conservados.	Políticas, registros, planes, actas, resultados, aprobaciones y evidencia de seguimiento.
6.1.2	Definir y aplicar criterios de riesgo de seguridad de la información y	Confirmar la propiedad, el alcance, el método, la aprobación, la	Políticas, registros, planes, actas, resultados, aprobaciones y

Cláusula	Significado claro	Enfoque de verificación	Evidencia de ejemplo
	métodos de evaluación coherentes; identificar a los propietarios y analizar y evaluar los riesgos.	evidencia operativa, las excepciones, la corrección y los registros conservados.	evidencia de seguimiento.
6.1.3	Elegir opciones y controles para el tratamiento del riesgo, compararlos con el Anexo A, elaborar la Declaración de Aplicabilidad y el plan de tratamiento, y obtener la aprobación del propietario del riesgo.	Confirmar la propiedad, el alcance, el método, la aprobación, la evidencia operativa, las excepciones, la corrección y los registros conservados.	Políticas, registros, planes, actas, resultados, aprobaciones y evidencia de seguimiento.
6.2	Establecer objetivos de seguridad medibles con propietarios, recursos, fechas y métodos de evaluación.	Confirmar la propiedad, el alcance, el método, la aprobación, la evidencia operativa, las excepciones, la corrección y los registros conservados.	Políticas, registros, planes, actas, resultados, aprobaciones y evidencia de seguimiento.
6.3	Planificar los cambios del SGSI de modo que se consideren su propósito, consecuencias, recursos, responsabilidades e integridad del sistema.	Confirmar la propiedad, el alcance, el método, la aprobación, la evidencia operativa, las excepciones, la corrección y los registros conservados.	Políticas, registros, planes, actas, resultados, aprobaciones y evidencia de seguimiento.

Utilice el texto oficial licenciado ISO/IEC 27001 para requisitos normativos exactos. Este manual parafrasea conceptos para la educación y no reemplaza el estándar.

9. Cláusula 7 - Apoyo

Requisitos de idiomas, enfoque de verificación y pruebas de ejemplo.

Propósito de la cláusula: Apoyo

Cláusula	Significado claro	Enfoque de verificación	Evidencia de ejemplo
7.1	Proporcionar las personas, la financiación, la tecnología y los demás recursos que necesita el SGSI.	Confirmar la propiedad, el alcance, el método, la aprobación, la evidencia operativa, las excepciones, la corrección y los registros conservados.	Políticas, registros, planes, actas, resultados, aprobaciones y evidencia de seguimiento.
7.2	Definir las necesidades de competencia, cerrar las brechas, evaluar los resultados y conservar evidencia.	Confirmar la propiedad, el alcance, el método, la aprobación, la evidencia operativa, las excepciones, la corrección y los registros conservados.	Políticas, registros, planes, actas, resultados, aprobaciones y evidencia de seguimiento.
7.3	Asegurar que las personas comprendan la política, su contribución y las consecuencias de la no conformidad.	Confirmar la propiedad, el alcance, el método, la aprobación, la evidencia operativa, las excepciones, la corrección y los registros conservados.	Políticas, registros, planes, actas, resultados, aprobaciones y evidencia de seguimiento.
7.4	Planificar qué, cuándo, con quién y cómo se comunica la organización interna y externamente.	Confirmar la propiedad, el alcance, el método, la aprobación, la evidencia operativa, las excepciones, la corrección y los registros conservados.	Políticas, registros, planes, actas, resultados, aprobaciones y evidencia de seguimiento.

Cláusula	Significado claro	Enfoque de verificación	Evidencia de ejemplo
7.5	Crear, aprobar, identificar, proteger, distribuir, conservar y controlar la información documentada requerida.	Confirmar la propiedad, el alcance, el método, la aprobación, la evidencia operativa, las excepciones, la corrección y los registros conservados.	Políticas, registros, planes, actas, resultados, aprobaciones y evidencia de seguimiento.

Utilice el texto oficial licenciado ISO/IEC 27001 para requisitos normativos exactos. Este manual parafrasea conceptos para la educación y no reemplaza el estándar.

10. Cláusula 8 - Operación

Requisitos de idiomas, enfoque de verificación y pruebas de ejemplo.

Propósito de la cláusula: Operación

Cláusula	Significado claro	Enfoque de verificación	Evidencia de ejemplo
8.1	Planificar y controlar los procesos del SGSI, los criterios, los cambios, el trabajo subcontratado y la evidencia de una operación adecuada.	Confirmar la propiedad, el alcance, el método, la aprobación, la evidencia operativa, las excepciones, la corrección y los registros conservados.	Políticas, registros, planes, actas, resultados, aprobaciones y evidencia de seguimiento.
8.2	Realizar evaluaciones de riesgos de seguridad de la información a intervalos planificados y cuando se produzcan cambios significativos.	Confirmar la propiedad, el alcance, el método, la aprobación, la evidencia operativa, las excepciones, la corrección y los registros conservados.	Políticas, registros, planes, actas, resultados, aprobaciones y evidencia de seguimiento.
8.3	Implementar el plan de tratamiento de riesgos y conservar	Confirmar la propiedad, el alcance, el método, la	Políticas, registros, planes, actas, resultados,

Cláusula	Significado claro	Enfoque de verificación	Evidencia de ejemplo
	evidencia de los resultados.	aprobación, la evidencia operativa, las excepciones, la corrección y los registros conservados.	aprobaciones y evidencia de seguimiento.

Utilice el texto oficial licenciado ISO/IEC 27001 para requisitos normativos exactos. Este manual parafrasea conceptos para la educación y no reemplaza el estándar.

11. Cláusula 9 - Evaluación del desempeño

Requisitos de idiomas, enfoque de verificación y pruebas de ejemplo.

Propósito de la cláusula: Evaluación del desempeño

Cláusula	Significado claro	Enfoque de verificación	Evidencia de ejemplo
9.1	Definir qué supervisar y medir, cómo y cuándo hacerlo, quién lo evalúa y cómo se conservan y analizan los resultados.	Confirmar la propiedad, el alcance, el método, la aprobación, la evidencia operativa, las excepciones, la corrección y los registros conservados.	Políticas, registros, planes, actas, resultados, aprobaciones y evidencia de seguimiento.
9.2.1	Realizar auditorías internas a intervalos planificados para evaluar la conformidad con los requisitos de la organización y de ISO/IEC 27001, así como su implementación eficaz.	Confirmar la propiedad, el alcance, el método, la aprobación, la evidencia operativa, las excepciones, la corrección y los registros conservados.	Políticas, registros, planes, actas, resultados, aprobaciones y evidencia de seguimiento.
9.2.2	Mantener un programa de auditoría con frecuencia, métodos,	Confirmar la propiedad, el alcance, el método, la aprobación, la	Políticas, registros, planes, actas, resultados, aprobaciones y

Cláusula	Significado claro	Enfoque de verificación	Evidencia de ejemplo
	responsabilidades, planificación, presentación de informes, alcance, criterios, auditores objetivos, resultados conservados y acciones correctivas oportunas.	evidencia operativa, las excepciones, la corrección y los registros conservados.	evidencia de seguimiento.
9.3.1	La alta dirección revisa el SGSI a intervalos planificados para asegurar su conveniencia, adecuación y eficacia continuas.	Confirmar la propiedad, el alcance, el método, la aprobación, la evidencia operativa, las excepciones, la corrección y los registros conservados.	Políticas, registros, planes, actas, resultados, aprobaciones y evidencia de seguimiento.
9.3.2	La revisión requiere elementos de entrada como acciones anteriores, cambios de contexto, necesidades de las partes interesadas, desempeño, retroalimentación, riesgo, tratamiento y oportunidades de mejora.	Confirmar la propiedad, el alcance, el método, la aprobación, la evidencia operativa, las excepciones, la corrección y los registros conservados.	Políticas, registros, planes, actas, resultados, aprobaciones y evidencia de seguimiento.
9.3.3	Registrar las decisiones de la revisión por la dirección sobre las mejoras y los cambios necesarios del SGSI.	Confirmar la propiedad, el alcance, el método, la aprobación, la evidencia operativa, las excepciones, la corrección y los registros conservados.	Políticas, registros, planes, actas, resultados, aprobaciones y evidencia de seguimiento.

Utilice el texto oficial licenciado ISO/IEC 27001 para requisitos normativos exactos. Este manual parafrasea conceptos para la educación y no reemplaza el estándar.

Gráfico 5 Corriente de trabajo de auditoría interna

12. Cláusula 10 - Mejora

Requisitos de idiomas, enfoque de verificación y pruebas de ejemplo.

Propósito de la cláusula: Mejora

Cláusula	Significado claro	Enfoque de verificación	Evidencia de ejemplo
10.1	Mejorar continuamente la conveniencia, la adecuación y la eficacia del SGSI.	Confirmar la propiedad, el alcance, el método, la aprobación, la evidencia operativa, las excepciones, la corrección y los registros conservados.	Políticas, registros, planes, actas, resultados, aprobaciones y evidencia de seguimiento.
10.2	Reaccionar ante las no conformidades, corregirlas, analizar sus causas, prevenir su recurrencia, verificar la eficacia y conservar evidencia.	Confirmar la propiedad, el alcance, el método, la aprobación, la evidencia operativa, las excepciones, la corrección y los registros conservados.	Políticas, registros, planes, actas, resultados, aprobaciones y evidencia de seguimiento.

Utilice el texto oficial licenciado ISO/IEC 27001 para requisitos normativos exactos. Este manual parafrasea conceptos para la educación y no reemplaza el estándar.

Gráfico 6 Temas de control del anexo A

13. Anexo A 5 Controles de organización

Resúmenes originales de los controles de referencia, el enfoque de verificación y los ejemplos de evidencia.

Control	Significado práctico	Enfoque de verificación	Evidencia de ejemplo
5.1	Mantener políticas aprobadas de seguridad de la información.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.

Control	Significado práctico	Enfoque de verificación	Evidencia de ejemplo
		medición.	
5.2	Definir las funciones y responsabilidades de seguridad.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
5.3	Separar las funciones incompatibles.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
5.4	Exigir a los responsables de gestión que hagan cumplir las responsabilidades de seguridad.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
5.5	Mantener un contacto adecuado con las autoridades.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
5.6	Participar en grupos de seguridad pertinentes y foros profesionales.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
5.7	Recopilar y utilizar inteligencia de amenazas.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.

Control	Significado práctico	Enfoque de verificación	Evidencia de ejemplo
		medición.	
5.8	Incorporar la seguridad en la gestión de proyectos.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
5.9	Inventariar la información y los activos asociados.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
5.10	Definir reglas de uso y manejo aceptables.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
5.11	Recuperar los activos de la organización cuando las funciones finalicen o cambien.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
5.12	Clasificar la información de acuerdo con la necesidad y el riesgo.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.

Control	Significado práctico	Enfoque de verificación	Evidencia de ejemplo
5.13	Etiquetar la información de manera coherente con su clasificación.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
5.14	Proteger las transferencias de información.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
5.15	Establecer reglas de control de acceso.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
5.16	Gestionar las identidades durante todo su ciclo de vida.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
5.17	Proteger la información de autenticación.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
5.18	Aprobar, revisar, modificar y eliminar los derechos de acceso.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
5.19	Gestionar el riesgo de	Confirmar el riesgo o	Procedimiento,

Control	Significado práctico	Enfoque de verificación	Evidencia de ejemplo
	seguridad en las relaciones con proveedores.	la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	configuración, registro, bitácora, ticket, revisión, prueba u observación.
5.20	Incluir requisitos de seguridad en los acuerdos con proveedores.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
5.21	Gestionar el riesgo de seguridad de la cadena de suministro de TIC.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
5.22	Supervisar, revisar y controlar los cambios en los servicios de proveedores.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
5.23	Gobernar la adquisición, el uso, la gestión y la salida de los servicios en la nube.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
5.24	Preparar y planificar la gestión de incidentes de seguridad.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
5.25	Evaluar los eventos y decidir si constituyen	Confirmar el riesgo o la obligación, el	Procedimiento, configuración,

Control	Significado práctico	Enfoque de verificación	Evidencia de ejemplo
	incidentes.	diseño, el propietario, la implementación, la operación, las excepciones y la medición.	registro, bitácora, ticket, revisión, prueba u observación.
5.26	Responder a los incidentes de seguridad.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
5.27	Aprender de los incidentes y mejorar los controles.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
5.28	Identificar, recopilar, adquirir y preservar evidencia.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
5.29	Proteger la información durante una interrupción.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
5.30	Preparar las TIC para respaldar la continuidad del negocio.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
5.31	Identificar y cumplir los requisitos legales, regulatorios y	Confirmar el riesgo o la obligación, el diseño, el propietario,	Procedimiento, configuración, registro, bitácora,

Control	Significado práctico	Enfoque de verificación	Evidencia de ejemplo
	contractuales.	la implementación, la operación, las excepciones y la medición.	ticket, revisión, prueba u observación.
5.32	Proteger los derechos de propiedad intelectual.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
5.33	Proteger los registros durante todo su ciclo de vida.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
5.34	Proteger la privacidad y la información de identificación personal.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
5.35	Organizar revisiones independientes de la seguridad de la información.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
5.36	Comprobar el cumplimiento de las políticas, reglas y normas de seguridad.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
5.37	Mantener procedimientos operativos documentados.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la	Procedimiento, configuración, registro, bitácora, ticket, revisión,

Control	Significado práctico	Enfoque de verificación	Evidencia de ejemplo
		operación, las excepciones y la medición.	prueba u observación.

Regla de selección: El Anexo A es un conjunto de referencia utilizado para comprobar que no se hayan omitido controles necesarios. La organización puede necesitar otros controles. Toda inclusión o exclusión debe justificarse mediante el tratamiento del riesgo y registrarse en la Declaración de Aplicabilidad.

Figura 7. Gestión de incidentes de seguridad

14. Anexo A 6 Controles de personas

Resúmenes originales de los controles de referencia, el enfoque de verificación y los ejemplos de evidencia.

Control	Significado práctico	Enfoque de verificación	Evidencia de ejemplo
6.1	Verificar a los candidatos y al personal de acuerdo con la ley, la función y el riesgo.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
6.2	Incluir responsabilidades de seguridad en las condiciones de empleo.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
6.3	Proporcionar concienciación, educación y formación continuas basadas en la función.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
6.4	Aplicar un proceso disciplinario justo y comunicado.	Confirmar el riesgo o la obligación, el diseño, el propietario,	Procedimiento, configuración, registro, bitácora,

Control	Significado práctico	Enfoque de verificación	Evidencia de ejemplo
		la implementación, la operación, las excepciones y la medición.	ticket, revisión, prueba u observación.
6.5	Gestionar las responsabilidades de seguridad después de la terminación o del cambio de función.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
6.6	Utilizar acuerdos adecuados de confidencialidad o no divulgación.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
6.7	Proteger la información durante el trabajo remoto.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
6.8	Facilitar la notificación oportuna de eventos de seguridad.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.

Regla de selección: El Anexo A es un conjunto de referencia utilizado para comprobar que no se hayan omitido controles necesarios. La organización puede necesitar otros controles. Toda inclusión o exclusión debe justificarse mediante el tratamiento del riesgo y registrarse en la Declaración de Aplicabilidad.

15. Anexo A 7 Controles físicos

Resúmenes originales de los controles de referencia, el enfoque de verificación y los ejemplos de evidencia.

Control	Significado práctico	Enfoque de verificación	Evidencia de ejemplo
7.1	Definir y proteger los perímetros de seguridad física.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
7.2	Controlar el acceso físico.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
7.3	Proteger oficinas, salas e instalaciones.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
7.4	Supervisar las instalaciones para detectar accesos físicos no autorizados.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
7.5	Proteger contra las amenazas físicas y ambientales.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
7.6	Aplicar reglas de trabajo para las áreas seguras.	Confirmar el riesgo o la obligación, el diseño, el propietario,	Procedimiento, configuración, registro, bitácora,

Control	Significado práctico	Enfoque de verificación	Evidencia de ejemplo
		la implementación, la operación, las excepciones y la medición.	ticket, revisión, prueba u observación.
7.7	Aplicar prácticas de escritorio limpio y pantalla limpia.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
7.8	Ubicar y proteger los equipos adecuadamente.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
7.9	Proteger los activos utilizados fuera de las instalaciones de la organización.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
7.10	Gestionar los medios de almacenamiento durante todo su ciclo de vida.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
7.11	Proteger los servicios de suministro.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
7.12	Proteger el cableado eléctrico y de datos.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la	Procedimiento, configuración, registro, bitácora, ticket, revisión,

Control	Significado práctico	Enfoque de verificación	Evidencia de ejemplo
		operación, las excepciones y la medición.	prueba u observación.
7.13	Mantener los equipos de forma segura.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
7.14	Eliminar o reutilizar los equipos de forma segura.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.

Regla de selección: El Anexo A es un conjunto de referencia utilizado para comprobar que no se hayan omitido controles necesarios. La organización puede necesitar otros controles. Toda inclusión o exclusión debe justificarse mediante el tratamiento del riesgo y registrarse en la Declaración de Aplicabilidad.

16. Anexo A 8 Controles tecnológicos

Resúmenes originales de los controles de referencia, el enfoque de verificación y los ejemplos de evidencia.

Control	Significado práctico	Enfoque de verificación	Evidencia de ejemplo
8.1	Proteger los dispositivos de punto final de usuario.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
8.2	Controlar los derechos de acceso privilegiado.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la	Procedimiento, configuración, registro, bitácora, ticket, revisión,

Control	Significado práctico	Enfoque de verificación	Evidencia de ejemplo
		operación, las excepciones y la medición.	prueba u observación.
8.3	Restringir el acceso a la información de acuerdo con la política.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
8.4	Controlar el acceso al código fuente y a las herramientas de desarrollo.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
8.5	Utilizar autenticación segura.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
8.6	Gestionar la capacidad.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
8.7	Proteger contra el malware.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
8.8	Gestionar las vulnerabilidades técnicas.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u

Control	Significado práctico	Enfoque de verificación	Evidencia de ejemplo
		excepciones y la medición.	observación.
8.9	Gestionar las configuraciones.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
8.10	Eliminar la información de forma segura cuando ya no sea necesaria.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
8.11	Enmascarar los datos confidenciales cuando corresponda.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
8.12	Prevenir la fuga de datos.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
8.13	Mantener y probar las copias de seguridad.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
8.14	Proporcionar redundancia cuando la disponibilidad lo requiera.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u

Control	Significado práctico	Enfoque de verificación	Evidencia de ejemplo
8.15	Generar, proteger, conservar y revisar registros.	medición. Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	observación. Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
8.16	Supervisar los sistemas y las redes para detectar comportamientos anómalos.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
8.17	Sincronizar los relojes.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
8.18	Controlar las utilidades potentes del sistema.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
8.19	Controlar la instalación de software en los sistemas en operación.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.

Control	Significado práctico	Enfoque de verificación	Evidencia de ejemplo
8.20	Proteger las redes.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
8.21	Proteger los servicios de red.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
8.22	Segregar las redes cuando sea necesario.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
8.23	Controlar el acceso a sitios web externos.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
8.24	Utilizar y gestionar la criptografía de forma adecuada.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
8.25	Operar un ciclo de vida de desarrollo seguro.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
8.26	Definir los requisitos	Confirmar el riesgo o	Procedimiento,

Control	Significado práctico	Enfoque de verificación	Evidencia de ejemplo
	de seguridad de las aplicaciones.	la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	configuración, registro, bitácora, ticket, revisión, prueba u observación.
8.27	Aplicar principios seguros de arquitectura e ingeniería.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
8.28	Utilizar prácticas de codificación segura.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
8.29	Realizar pruebas de seguridad durante el desarrollo y la aceptación.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
8.30	Controlar el desarrollo subcontratado.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
8.31	Separar los entornos de desarrollo, prueba y producción.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
8.32	Gestionar los cambios de forma segura.	Confirmar el riesgo o la obligación, el	Procedimiento, configuración,

Control	Significado práctico	Enfoque de verificación	Evidencia de ejemplo
		diseño, el propietario, la implementación, la operación, las excepciones y la medición.	registro, bitácora, ticket, revisión, prueba u observación.
8.33	Proteger la información de prueba.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.
8.34	Proteger los sistemas operativos durante las pruebas de auditoría.	Confirmar el riesgo o la obligación, el diseño, el propietario, la implementación, la operación, las excepciones y la medición.	Procedimiento, configuración, registro, bitácora, ticket, revisión, prueba u observación.

Regla de selección: El Anexo A es un conjunto de referencia utilizado para comprobar que no se hayan omitido controles necesarios. La organización puede necesitar otros controles. Toda inclusión o exclusión debe justificarse mediante el tratamiento del riesgo y registrarse en la Declaración de Aplicabilidad.

17. Controles de implementación con ISO/IEC 27002

Cómo convertir las decisiones de riesgo en controles que se ajusten a la organización.

1. Comience con la decisión, obligación y resultado esperado del tratamiento de riesgos, no con una herramienta.
2. Use ISO/IEC 27002 guía y atributos pertinentes para comprender el propósito, las consideraciones de aplicación y las relaciones.
3. Adaptar el control a las personas, procesos, tecnología, entorno físico, limitaciones legales y operaciones empresariales.
4. Definir propietario, alcance, disparador, entradas, pasos, salidas, registros, frecuencia, dependencias, excepciones y escalada.
5. Evaluar si el diseño alcanzaría razonablemente el resultado previsto.

6. Aplicar mediante cambios controlados y capacitar a las personas afectadas.
7. Medir el funcionamiento y la eficacia, investigar excepciones y mejorar.
8. Actualizar riesgos, plan de tratamiento, SoA, procedimientos y evidencia cuando el control cambia.

Distinción importante: ISO/IEC 27002 proporciona orientación. La organización sigue siendo responsable de seleccionar y diseñar controles que traten sus riesgos y cumplan los requisitos aplicables.

18. Pruebas de medición y control

Cómo verificar si el ISMS y sus controles funcionan.

Área	Población y muestra	Prueba	Evidencia
Riesgo	Todos los riesgos actuales; muestrear elementos altos, modificados, aceptados y vencidos	Repetir la puntuación, rastrear el tratamiento y confirmar la aprobación y revisión del propietario	Método, registro, aprobaciones, tratamiento y riesgo residual
Acceso	Todas las identidades de la fuerza laboral, privilegiadas, de servicio y de terceros	Comprobar la necesidad, la aprobación, MFA, la revisión, el cambio, la inactividad y la baja	Poblaciones, exportaciones, tickets, configuraciones y registros
Vulnerabilidades	Todos los activos y hallazgos	Validar la cobertura, la priorización, las excepciones, los plazos, la corrección y el nuevo análisis	Inventario, análisis, tickets, aprobaciones y nuevas pruebas
Proveedores	Población completa de proveedores; muestrear servicios críticos y modificados	Comprobar la diligencia debida, el acuerdo, la responsabilidad, el seguimiento, los incidentes y la salida	Inventario, evaluación, contrato, revisión y evidencia de terminación
Incidentes	Todos los eventos e incidentes notificados	Comprobar la clasificación, la respuesta, la evidencia, las comunicaciones, la recuperación y el	Casos, cronología, decisiones, registro de evidencias y lecciones

Área	Población y muestra	Prueba	Evidencia
Continuidad	Procesos críticos y TIC de apoyo	aprendizaje Rastrear las necesidades del negocio hasta el diseño de recuperación y los ejercicios	BIA, planes, registros de pruebas, brechas y nuevas pruebas
Objetivos	Todos los objetivos y mediciones del SGSI	Comprobar la definición, la calidad de los datos, la tendencia, el objetivo, el análisis, la decisión y la acción	Definiciones de métricas, datos fuente, cuadros de mando, actas y acciones
- Definir criterios exactos, alcance, período, población, control, propietario, evidencia y resultados esperados. - Evaluar el diseño antes de la operación de prueba. - Obtener la población completa y validar su integridad y exactitud independientemente. - Seleccione una muestra basada en el riesgo que cubra las fechas, propietarios, ubicaciones, fallos, excepciones y cambios pertinentes. - Inspeccionar registros, observar el trabajo, entrevistar personal, examinar la configuración y repercutir cuando sea práctico. - Excepciones de documentos como hechos vinculados a criterios; no exageren ni escondan limitaciones. - Corrección de la asignación, análisis de la raíz, propietario, fecha prevista, protección provisional y escalada. - Reprueba y declara la conclusión final y la limitación restante.			

19. Auditoría interna

- Una evaluación independiente de la conformidad y la aplicación efectiva*.

Mantener un programa de auditoría que considere la importancia del proceso, el cambio, el riesgo y los resultados anteriores.

Definir objetivos, alcance, criterios, calendario, método, muestreo, registros y presentación de informes para cada auditoría.

Select auditors who are competent and sufficiently objective; auditors should not audit their own work without safeguards.

Utilice las normas, requisitos de organización, decisiones de riesgo, SoA, políticas y obligaciones aplicables como criterios.

Registre la evidencia y los hallazgos con suficiente claridad para que otra persona competente pueda comprender el fundamento.

Report results to relevant management and track corrections and corrective actions through effectiveness review.

Tipo de hallazgo	Significado	Respuesta requerida
Conformidad	La evidencia respalda los criterios	Mantener y supervisar
Oportunidad de mejora	Una sugerencia útil de mejora que no es una no conformidad oculta	Evaluar voluntariamente y registrar la decisión
No conformidad	Uno o más requisitos no se cumplen	Corregir, analizar la causa, actuar para prevenir la recurrencia y verificar la eficacia
Limitación de la auditoría	El alcance, la evidencia, el tiempo, la independencia o el acceso restringieron la conclusión	Comunicar con claridad y resolver cuando sea posible

20. Revisión por la dirección y acción correctiva

- Decisiones de liderazgo que mantienen el ISMS adecuado y efectivo.*

Entrada para la revisión por la dirección	Preguntas
Acciones anteriores	¿Se completaron las decisiones anteriores y fueron eficaces?
Contexto y partes interesadas	¿Qué ha cambiado, incluida la pertinencia del cambio climático y las necesidades de las partes interesadas?
Desempeño	¿Qué muestran las métricas, los objetivos, los incidentes, los resultados de auditoría y las no conformidades?
Comentarios de las partes interesadas	¿Qué informan los clientes, los reguladores, los trabajadores, los proveedores y los propietarios?
Riesgo y tratamiento	¿Siguen siendo adecuados los niveles de riesgo, la aceptación, el tratamiento, los recursos y la SoA?
Oportunidades de mejora	¿Qué cambios debe aprobar la dirección?

- Contener o corregir el problema inmediato.

- Determinar el alcance y si existen fallos similares en otros lugares.
- Analizar la causa raíz utilizando evidencia, no buscando culpables.
- Plan de acción proporcional al efecto y al riesgo de recurrencia.
- Realizar cambios en materia de propiedad y fechas debidas.
- Verificar la eficacia utilizando pruebas definidas después de tiempo suficiente.
- Actualizar riesgos, controles, documentos, capacitación, objetivos y SoA cuando sea necesario.

21. Certificación

Qué certificación hace, cómo procede generalmente, y lo que no garantiza.

Figura 8. Carretera de certificación

La certificación es opcional; las organizaciones pueden implementar ISO/IEC 27001 sin solicitar un certificado.

ISO no realiza certificación. Un órgano de certificación independiente realiza auditorías de certificación.

La acreditación proporciona confianza adicional en la competencia de un órgano de certificación; verificar el alcance de acreditación y certificado pertinente.

La etapa 1 generalmente evalúa la preparación, el alcance, el sistema documentado y la preparación para la auditoría de la ejecución.

La etapa 2 evalúa la aplicación y la eficacia en todo el ámbito definido.

Las actividades de vigilancia y recertificación evalúan la conformidad continua; los detalles deben confirmarse con el órgano de certificación seleccionado y las normas de acreditación.

Un certificado tiene alcance y plazo. No prueba que cada producto es seguro, que no puede ocurrir ningún incidente, o que cada sistema en la empresa está incluido.

Área de preparación	Comprobación de aceptación
Alcance	Claro, justificable y reflejado en las operaciones reales y en el propósito del certificado
Riesgo	Método utilizado de forma coherente; registro completo; los propietarios aceptan el riesgo residual
SoA	Todos los controles del Anexo A abordados; selecciones, exclusiones y estado sustentados
Controles	Implementados, operados durante el tiempo

Área de preparación	Comprobación de aceptación
Auditoría interna	suficiente para producir evidencia fiable y medidos Programa y auditoría de alcance completo finalizados con evidencia objetiva y seguimiento
Revisión por la dirección	Entradas requeridas consideradas y decisiones registradas
Acción correctiva	No conformidades corregidas; causa y eficacia abordadas
Enmienda	Pertinencia del cambio climático y requisitos de las partes interesadas considerados y evidenciados

22. Herramientas de código abierto

- Enlaces oficiales, inicios rápidos seguros, pruebas y limitaciones.*

Herramienta	Propósito	Posible apoyo
CISO Assistant	intuitem.github.io	SGSI, riesgos, controles y evidencia
SimpleRisk Community	www.simplerisk.com	Registro de riesgos y tratamiento
Wazuh	wazuh.com	SIEM, supervisión de endpoints y FIM
osquery	www.osquery.io	Inventario y consultas de endpoints
OpenSCAP	www.open-scap.org	Evaluación de la configuración de Linux
Greenbone Community Edition	greenbone.github.io	Gestión de vulnerabilidades
Nmap	nmap.org	Descubrimiento de activos y servicios
Trivy	trivy.dev	Análisis de código, imágenes, dependencias, secretos y configuración
OWASP ZAP	www.zaproxy.org	Pruebas autorizadas de aplicaciones web
Keycloak	www.keycloak.org	Identidad, MFA, roles y registros
DefectDojo	www.defectdojo.org	Recepción de hallazgos y remediación

Herramienta	Propósito	Posible apoyo
AIDE	aide.github.io	Supervisión de la integridad de archivos
Lynis	cisofy.com	Auditoría de seguridad de Linux
Open Policy Agent	www.openpolicyagent.org	Políticas como código

Limitación crítica: Las herramientas apoyan los controles y la evidencia; no seleccionan el tratamiento del riesgo, determinan la conformidad, sustituyen a auditores competentes ni certifican una organización. Validar la cobertura, la calidad de los datos, la configuración, los permisos, las actualizaciones y la revisión humana.

22.1 CISO Assistant

Propósito: ISMS, riesgos, controles, evidencia. Proyecto oficial: Seguido

Inicio rápido seguro: Implementar en un entorno de prueba aislado; crear un proyecto marco, alcance, registro de riesgos, acciones de tratamiento, propietarios y registros de pruebas.

Pruebas: alcance aprobado, configuración, versión, cobertura, resultados, revisión, excepción, remediación y retest. Protege credenciales, registros, informes y copias de seguridad.

22.2 SimpleRisk Community

Propósito: Registro de riesgos y tratamiento. Proyecto oficial: ejecutado SimpleRisk Comunidad efectuada/u contacto

Inicio rápido seguro: Instalar de forma segura, definir criterios de riesgo, registrar riesgos y propietarios, elegir tratamientos, rastrear las fechas debidas y exportar informes revisados.

Pruebas: alcance aprobado, configuración, versión, cobertura, resultados, revisión, excepción, remediación y retest. Protege credenciales, registros, informes y copias de seguridad.

22.3 Wazuh

Propósito: SIEM, monitoreo de puntos finales, FIM. Proyecto oficial: Seguido

Inicio rápido seguro: Instalar un gestor de laboratorio y agente, confirmar la inscripción, desencadenar un evento de prueba autorizado, revisar la alerta, y preservar la configuración y la evidencia de alerta.

Pruebas: alcance aprobado, configuración, versión, cobertura, resultados, revisión, excepción, remediación y retest. Protege credenciales, registros, informes y copias de seguridad.

22.4 osquery

Propósito: Inventario de punto final y consultas. Proyecto oficial:

Inicio rápido seguro: Instalar en un host de laboratorio, ejecutar consultas sólo lectura para software, usuarios, procesos o ajustes, programar consultas aprobadas, y cobertura de documentos.

Pruebas: alcance aprobado, configuración, versión, cobertura, resultados, revisión, excepción, remediación y retest. Protege credenciales, registros, informes y copias de seguridad.

22.5 OpenSCAP

Propósito: Evaluación de configuración de Linux. Proyecto oficial: Seguido

Inicio rápido seguro: Seleccione un perfil apropiado, escanear un sistema de laboratorio, validar los resultados manualmente, registrar excepciones, remediar, y cambiar.

Pruebas: alcance aprobado, configuración, versión, cobertura, resultados, revisión, excepción, remediación y retest. Protege credenciales, registros, informes y copias de seguridad.

22.6 Greenbone Community Edition

Objetivo: Gestión de la vulnerabilidad. Proyecto oficial: ejecutado Greenbone Community Edition 10

Comenzar rápido seguro: Autorizar objetivos, actualizar los piensos, realizar escaneos de laboratorio autenticados, validar la cobertura y los hallazgos, asignar la remediación y cambiar.

Pruebas: alcance aprobado, configuración, versión, cobertura, resultados, revisión, excepción, remediación y retest. Protege credenciales, registros, informes y copias de seguridad.

22.7 Nmap

Propósito: Activo y descubrimiento de servicio. Proyecto oficial: Seguido

Comenzar rápido seguro: Usar sólo en rangos autorizados; empezar con un escaneo de servicio limitado, comparar resultados con inventario, investigar desconocidos, y retener comando y alcance.

Pruebas: alcance aprobado, configuración, versión, cobertura, resultados, revisión, excepción, remediación y retest. Protege credenciales, registros, informes y copias de seguridad.

22.8 Trivy

Propósito: Código, imagen, dependencia, secreto y análisis de configuración. Proyecto oficial: Seguido

Inicio rápido seguro: Escanear un repositorio de prueba o imagen de contenedor, validar hallazgos, suprimir sólo con aprobación y razón, fijar y rescán.

Pruebas: alcance aprobado, configuración, versión, cobertura, resultados, revisión, excepción, remediación y retest. Protege credenciales, registros, informes y copias de seguridad.

22.9 OWASP ZAP

Propósito: Pruebas de aplicación web autorizadas. Proyecto oficial: Seguido

Comenzar rápido seguro: Proxy una aplicación de entrenamiento, arrastrar pasivamente, utilizar el escaneo activo sólo con aprobación escrita, validar resultados y registrar la remediación.

Pruebas: alcance aprobado, configuración, versión, cobertura, resultados, revisión, excepción, remediación y retest. Protege credenciales, registros, informes y copias de seguridad.

22.10 Keycloak

Objetivo: Identidad, MFA, roles y registros. Proyecto oficial: Seguido

Comenzar rápido seguro: Crear un reino de laboratorio, usuarios, grupos, roles de menor privilegio, MFA, configuración de sesión y eventos; pruebas de unión, mudanza y casos de licencia.

Pruebas: alcance aprobado, configuración, versión, cobertura, resultados, revisión, excepción, remediación y retest. Protege credenciales, registros, informes y copias de seguridad.

22.11 DefectoDojo

Propósito: Encontrar ingesta y remediación. Proyecto oficial: Seguido

Inicio rápido seguro: Importar resultados de escáner seguros, cuidadosamente deduplicar, asignar propietarios, establecer plazos basados en el riesgo, adjuntar pruebas, y cerrar sólo después de la prueba.

Pruebas: alcance aprobado, configuración, versión, cobertura, resultados, revisión, excepción, remediación y retest. Protege credenciales, registros, informes y copias de seguridad.

22.12 AIDE

Propósito: Monitoreo de la integridad de archivos. Proyecto oficial: ejecutar

Inicio rápido seguro: Crear una línea de referencia en un host de laboratorio, hacer un cambio de archivo autorizado, ejecutar un cheque, investigar la diferencia y proteger la base de referencia.

Pruebas: alcance aprobado, configuración, versión, cobertura, resultados, revisión, excepción, remediación y retest. Protege credenciales, registros, informes y copias de seguridad.

22.13 Lynis

Propósito: Auditoría de seguridad de Linux. Proyecto oficial: Seguido

Inicio rápido seguro: Auditoría de un anfitrión de laboratorio, revisión de sugerencias contra el alcance y el riesgo, decisiones de documentos, remediar elementos seleccionados y repetir.

Pruebas: alcance aprobado, configuración, versión, cobertura, resultados, revisión, excepción, remediación y retest. Protege credenciales, registros, informes y copias de seguridad.

22.14 Open Policy Agent

Propósito: Política como código. Proyecto oficial: Seguido

Inicio rápido seguro: Escribir una pequeña regla de laboratorio, probar los insumos permitidos y negados, ver la política y las pruebas, y preservar los resultados como evidencia de apoyo.

Pruebas: alcance aprobado, configuración, versión, cobertura, resultados, revisión, excepción, remediación y retest. Protege credenciales, registros, informes y copias de seguridad.

23. Manual del SGSI para gerentes

Las preguntas, el tablero, la propiedad y los administradores de decisiones deben controlar.

¿El alcance del ISMS sigue alineado con la estrategia, los servicios, las ubicaciones, los proveedores, el uso de la nube, las personas y los flujos de datos?

¿Qué cambió en el contexto, las partes interesadas, las obligaciones legales, las amenazas, la tecnología o la relevancia climática?

¿Son fiables los criterios de riesgo y los propietarios aprueban explícitamente el tratamiento y el riesgo residual?

¿El SoA coincide con la implementación del control real y las acciones abiertas?

¿Son objetivos y métricas que producen decisiones en lugar de paneles decorativos?

¿Se han intensificado los incidentes, las conclusiones de las auditorías, las excepciones, las medidas atrasadas y los fallos repetidos?

¿El examen interno de auditoría y gestión tiene suficiente independencia, competencia, tiempo y pruebas?

¿Son exactas las reclamaciones de certificación, alcance, acreditación y declaraciones de clientes?

Área	Pregunta para la dirección	Estado
Contexto y alcance	¿Están actualizados los límites, las dependencias, las partes y los cambios?	Verde / Amarillo / Rojo
Riesgo	¿Son coherentes los criterios y oportunas las decisiones del propietario?	Verde / Amarillo / Rojo
SoA y controles	¿Están alineados la selección, el estado y la evidencia?	Verde / Amarillo / Rojo
Desempeño	¿Impulsan acciones los	Verde / Amarillo / Rojo

Área	Pregunta para la dirección	Estado
	objetivos, las métricas, los incidentes y las tendencias?	
Proveedores	¿Están controlados el riesgo, la responsabilidad, el seguimiento, los incidentes y las salidas?	Verde / Amarillo / Rojo
Aseguramiento	¿Son objetivas las auditorías y se corrigen eficazmente los hallazgos?	Verde / Amarillo / Rojo
Mejora	¿Se abordan las causas raíz, la recurrencia y las lecciones?	Verde / Amarillo / Rojo
Certificación	¿Tienen un alcance definido, están vigentes y son sustentables las afirmaciones?	Verde / Amarillo / Rojo

24. Junior Analyst Career Guide

Una ruta práctica hacia ISMS, GRC, riesgo, auditoría y cumplimiento.

Figura 9. Vía analista Junior ISO 27001

Junior GRC Analista

Analista de Cumplimiento ISO 27001

Analista de Controles de Seguridad

ISMS Coordinator

Análisis de riesgos

Internal Audit Associate

Third-Party Risk Analyst

Análisis de la seguridad

24.1 Típico trabajo junior

- Mantener el alcance, activo, obligación, proveedor, riesgo, control, SoA, evidencia, hallazgo y registros de acción.
- Reunir pruebas sin cambiar los registros de fuentes y validar la integridad.
- Mapa de riesgos y requisitos para controles, propietarios, procedimientos, sistemas y pruebas.

- Prueba de muestras de acceso, cambio, vulnerabilidad, incidencia, respaldo, proveedor, conciencia, control físico y continuidad.
- Apoyar auditorías internas, exámenes de gestión, métricas, acciones correctivas y preparación de certificación.
- Escribir conclusiones fácticas y revelar muestreo, alcance y limitaciones de evidencia.
- Proteger información confidencial y permanecer dentro de la autorización.

24.2 Habilidades que valoran los empleadores

Habilidad	Evidencia
Conceptos de SGSI	Explicar las cláusulas 4–10 y la mejora continua
Riesgo	Elaborar un registro y un plan de tratamiento coherentes
SoA	Justificar las selecciones, exclusiones, el estado y la evidencia
Pruebas de evidencia	Definir poblaciones, muestras, procedimientos, excepciones y repeticiones de pruebas
Conocimientos técnicos	Interpretar evidencia de identidad, nube, registros, vulnerabilidades, copias de seguridad y configuración
Comunicación	Redactar conclusiones, acciones y resúmenes de gestión concisos
Ética	Utilizar datos sintéticos, sistemas autorizados y afirmaciones honestas

25. Laboratorio ficticio y portafolio

Un entorno seguro de práctica con datos sintéticos y sistemas de laboratorio autorizados.

Regla del laboratorio: Utilice una organización ficticia, datos sintéticos, sistemas aislados y herramientas que esté autorizado a operar. No afirme que un proyecto de portafolio sea una certificación real ni una auditoría de cliente.

1. Cree una empresa ficticia con dos productos, un servicio en la nube, una fuerza laboral remota y tres proveedores.
2. Redacte un análisis de contexto de una página, un registro de partes interesadas, una determinación de pertinencia climática y una declaración de alcance.
3. Cree criterios de riesgo y un registro de diez escenarios con propietarios y decisiones de tratamiento.

4. Cree un plan de tratamiento y una Declaración de Aplicabilidad que aborde los 93 controles del Anexo A con justificaciones concisas y un estado de implementación honesto.
5. Elabore políticas, procedimientos, objetivos, métricas, registros de activos y proveedores, un registro de capacitación, un registro de incidentes y un ejercicio de continuidad.
6. Utilice algunas herramientas de código abierto en laboratorios aislados y conserve evidencia del alcance, la configuración, los resultados, la validación, la remediación y la repetición de pruebas.
7. Diseñe y ejecute un plan de auditoría interna sobre cláusulas y controles seleccionados.
8. Redacte dos no conformidades, registros de causa raíz, acciones correctivas y pruebas de eficacia.
9. Prepare actas de revisión por la dirección que muestren entradas, decisiones, propietarios, recursos y plazos.
10. Publique únicamente artefactos depurados y sintéticos con una declaración clara de limitaciones.

Artefacto del portafolio	Qué demuestra
Contexto, partes interesadas y alcance	Razonamiento y límites de la cláusula 4
Método, registro y tratamiento de riesgos	Cláusula 6 y propiedad del riesgo
Declaración de Aplicabilidad	Decisiones de control trazables
Papel de trabajo de prueba de controles	Evidencia, muestreo, excepciones y conclusión
Paquete de auditoría interna	Programa, plan, criterios, informe y seguimiento
Actas de revisión por la dirección	Evaluación y decisiones de liderazgo
Registro de acción correctiva	Causa raíz y eficacia
Memorando de evidencia de herramientas	Conocimientos técnicos y limitaciones

26. Plan de aprendizaje de 30 días

Un calendario centrado para la creación de capacidad útil de nivel junior.

Días	Enfoque	Entregable
1–5	ISMS, CIA, cláusulas, relación entre ISO 27001 e ISO 27002, alcance	Mapa conceptual de una página y declaración de alcance
6–10	Criterios de riesgo, escenarios, evaluación, tratamiento, aceptación	Registro de diez riesgos y plan de tratamiento

Días	Enfoque	Entregable
11–14	Temas del Anexo A y Declaración de Aplicabilidad	SoA ficticia completa
15–18	Políticas, competencia, comunicación, control de documentos, operaciones	Índice de evidencias y tres procedimientos de muestra
19–22	Métricas, seguimiento, auditoría interna, revisión por la dirección	Hoja de métricas, plan de auditoría y agenda de revisión
23–25	No conformidad, causa raíz, acción correctiva, mejora	Dos registros de hallazgos y acciones correctivas
26–28	Laboratorios autorizados de herramientas de código abierto	Dos memorandos de evidencia y repetición de pruebas
29–30	Depuración de la cartera y práctica de entrevistas	Cartera depurada y cinco historias STAR

27. Preparación de entrevistas

- Respuestas claras, escenarios prácticos y preguntas para el empleador.*

27.1 ¿Qué es un ISMS?

Un sistema de gestión para controlar el riesgo de seguridad de la información mediante liderazgo, planificación, operación, evaluación y mejora continua.

27.2 ISO 27001 versus 27002?

27001 contiene requisitos certificables de ISMS; 27002 proporciona orientación de control detallada y no es en sí mismo un estándar de certificación.

27.3 ¿Qué es el SoA?

A controlled record of necessary controls, Annex A inclusion or exclusion justification, and implementation status, linked to treatment and evidence.

27.4 ¿Todos los controles del Anexo A son obligatorios?

La organización debe utilizar el Anexo A como verificación de referencia y justificar decisiones. Los controles necesarios siguen el tratamiento y las obligaciones de riesgo; también pueden requerirse otros controles.

27.5 ¿Cómo prueba un control?

Definir los criterios y el alcance, validar la población, muestras por riesgo, inspeccionar y repercutir pruebas, excepciones de documentos y reprueba la corrección.

27.6 ¿Qué es una no conformidad?

No cumplir con un requisito. Se requiere corrección, evaluación de causas, acción adecuada y examen de eficacia.

27.7 ¿Qué cambió en 2024?

La enmienda exige una consideración explícita de la pertinencia del cambio climático en el contexto y observa que las partes interesadas pueden tener requisitos relacionados con el clima.

27.8 ¿Qué puede concluir un analista junior con seguridad?

Los hechos estatales respaldados por pruebas y alcance definidos, revelan limitaciones y evitan reclamar auditor o autoridad de certificación.

27.9 Preguntas para hacer al empleador

- ¿Cuál es el alcance de ISMS certificado o previsto?
- ¿Quién posee la aceptación del riesgo y el SoA?
- ¿Cómo se producen y validan las poblaciones de pruebas?
- ¿Qué sistemas gestionan riesgos, controles, proveedores, hallazgos y acciones correctivas?
- ¿Cómo se mantiene la independencia del auditor interno?
- ¿Con qué equipos técnicos trabajarán?
- ¿Cómo se revisan y entrenan las conclusiones junior?

28. Plantillas, glosario, índice y referencias

Estructuras de trabajo reutilizables, términos importantes y puntos de partida autorizados.

28.1 Registro mínimo de riesgos

Campo	Entrada
ID del riesgo y propietario	_____
Objetivo o activo	_____
Evento de amenaza y condición	_____
Consecuencia	_____
Controles existentes	_____
Probabilidad e impacto	_____
Riesgo actual	_____
Tratamiento y propietario de la acción	_____
Riesgo residual y aceptación	_____

Campo	Entrada
Fecha de revisión	_____

28.2 Papel de trabajo de prueba de controles

Campo	Entrada
Criterios y control	_____
Alcance y período	_____
Propietario y sistemas	_____
Población y comprobación de integridad	_____
Muestra y justificación	_____
Procedimiento realizado	_____
Evidencia examinada	_____
Excepciones	_____
Conclusión y limitación	_____
Corrección y repetición de la prueba	_____

28.3 Glosario

Término	Significado
Anexo A	Conjunto de referencia de 93 controles de seguridad de la información en ISO/IEC 27001:2022.
CIA	Confidencialidad, integridad y disponibilidad.
Conformidad	Cumplimiento de un requisito.
Control	Medida que modifica o mantiene el riesgo.
Acción correctiva	Acción que aborda la causa de una no conformidad para evitar su recurrencia.
Información documentada	Información que la organización debe controlar y mantener o conservar.
Parte interesada	Persona u organización que puede afectar, verse afectada o percibirse afectada por una decisión o actividad.
SGSI	Sistema de gestión de la seguridad de la información.
No conformidad	Incumplimiento de un requisito.
Riesgo residual	Riesgo que permanece después del tratamiento.
Propietario del riesgo	Persona o entidad responsable y autorizada para gestionar un riesgo.
SoA	Declaración de Aplicabilidad.
Alta dirección	Persona o grupo que dirige y controla la

Término	Significado
	organización al más alto nivel dentro del alcance.

28.4 Índice temático

Tema	Secciones
Controles del Anexo A	13–16
Auditoría	19
Certificación	21
Cambio climático	2, 6, 20
Acción correctiva	12, 20
Evidencia	5, 18
Partes interesadas	2, 6
Analista junior	24–27
Revisión por la dirección	20
Métricas	11, 18
Herramientas de código abierto	22
Evaluación y tratamiento de riesgos	3, 8
Alcance	2, 6
Declaración de Aplicabilidad	4
Proveedores	13, 18, 23

28.5 Referencias oficiales

[ISO/IEC 27001:2022 overview](#)

[ISO/IEC 27001:2022/Amd 1:2024](#)

[ISO/IEC 27002:2022 overview](#)

[Nota de cambio climático](#)

[Según la descripción de la certificación efectuada](#)

[ISO/IEC 27000 family](#)

Recuerdo final: Adquirir o acceder legalmente a las normas oficiales antes de su aplicación o evaluación. Confirme las ediciones, enmiendas, acreditación, alcance de certificación, requisitos legales, contratos, tecnología, amenazas y cambio organizativo. |